

Controls and Compliance Checklist

Botium Toys | Cybersecurity Audit

This checklist assesses Botium Toys' current controls and compliance posture, based on the Scope, Goals, and Risk Assessment Audit Report.

Controls Assessment Checklist

Does Botium Toys currently have this control in place?

Yes	No	Control
	✓	Least Privilege
	✓	Disaster recovery plans
	✓	Password policies
	✓	Separation of duties
✓		Firewall
	✓	Intrusion detection system (IDS)
	✓	Backups
✓		Antivirus software
	✓	Manual monitoring, maintenance, and intervention for legacy systems
	✓	Encryption
	✓	Password management system
✓		Locks (offices, storefront, warehouse)
✓		Closed-circuit television (CCTV) surveillance
✓		Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance Checklist

Does Botium Toys currently adhere to this compliance best practice?

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best Practice
	✓	Only authorized users have access to customers' credit card information.
	✓	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
	✓	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
	✓	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best Practice
✓		E.U. customers' data is kept private/secured.
✓		There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
	✓	Ensure data is properly classified and inventoried.
✓		Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC Type 1, SOC Type 2)

Yes	No	Best Practice
	✓	User access policies are established.
	✓	Sensitive data (PII/SPII) is confidential/private.
✓		Data integrity ensures the data is consistent, complete, accurate, and has been validated.
	✓	Data is available to individuals authorized to access it.

Recommendations

Based on the risk assessment findings and the results of the controls and compliance checklist above, the following recommendations are proposed to reduce risk and improve Botium Toys' security posture:

1. Turn on Multi-Factor Authentication (MFA) for all staff logins to stop unauthorized account access.
2. Encrypt customer personal info and credit card details to comply with GDPR and PCI DSS and avoid heavy fines.
3. Restrict employee access to sensitive data based on their job role (Least Privilege).
4. Create a disaster recovery plan to restore data and systems during a breach or outage.
5. Deploy an Intrusion Detection System (IDS) to monitor network traffic for malicious activity and alert administrators.
6. Adopt a password management system to centrally enforce password policy requirements.
7. Implement regular, automated backups of critical business data, stored separately from primary systems, to ensure recovery in the event of data loss or a ransomware attack.
8. Enforce separation of duties for financial and data-handling processes, so no single employee has end-to-end control over sensitive transactions.